

Closing the Loop

Auto-Remediation for the Cloud You Actually Run

Detection was never the hard part. Fixing it at scale is.



"We already have a CSPM. Now what?"



Deploy CSPM

Cloud Security Posture Management

Due: Jun 3

Assigned to: Larry Lease

Priority: High |



Visibility got solved. **Fixing it at scale** didn't.



Who we are



Samuel

~~Cloud Security~~ Site Reliability Engineer at Flywire.
Designing, building, and operating security and networking
infrastructure at scale.

unicrons.cloud

🏃 hyrox · 🥁 drums · 🎹 piano

🐙 sbldevnet

in samuelburgos

☁ samuelburgos.cloud



Andoni

DevSecOps Engineer at Crossmint.
Securing the product and every phase of the software
development lifecycle. Opensource & Community ❤️

unicrons.cloud

🏃 running · 🎾 padel · 📧 hacking

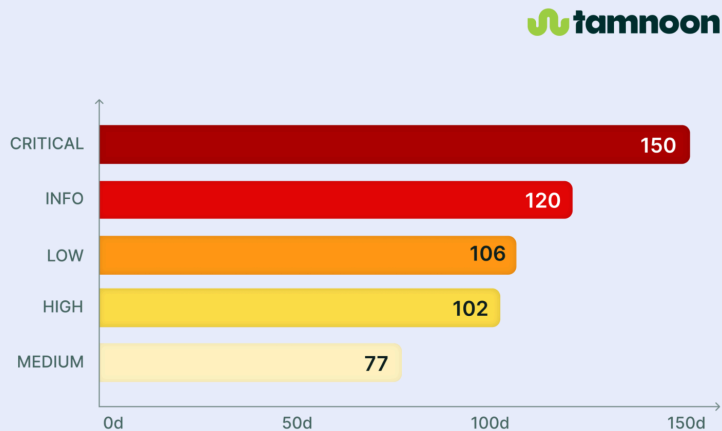
🐙 andoniaf

in andoniaf

☁ andoni.cloud



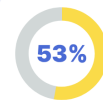
Average Days to Close, by Source-CNAPP Severity Tag (2026)



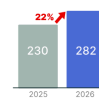
2026 State of Cloud Remediation Report

Mean days to close - Severity tag as labeled by source CNAPP - Severity classifications are not standardized across vendors — read the relative ordering, not the absolute boundaries

KEY CLOUD SECURITY TRENDS



of all CNAPP-detected alerts remain OPEN so far in 2026.



22% increase in Vulnerability Management MTTR YoY, from 230 to 282 days.



of all alerts come from the same 8 misconfigurations seen last year.



150 days

was the average exposure window for Critical alerts before remediation ships.



6.3%

of open alerts touch a Crown Jewel asset.

13%*

of all alerts were classified as critical in 2026, up from 1.4% in 2025.



<https://tamnoon.io/state-of-cloud-remediation/>

*"Over half of the vulnerabilities addressed by organizations tend to **recur within a month** of remediation."*

Cloud Security Alliance — State of Security Remediation 2024



<https://cloudsecurityalliance.org/artifacts/the-state-of-security-remediation-survey-report>

*"37% describe their automation as largely **alert-focused**... only **11%** report autonomous remediation capable of acting without human intervention."*

Fortinet — Cloud Security Report 2026



<https://www.fortinet.com/resources/reports/cloud-security>



What are we missing?

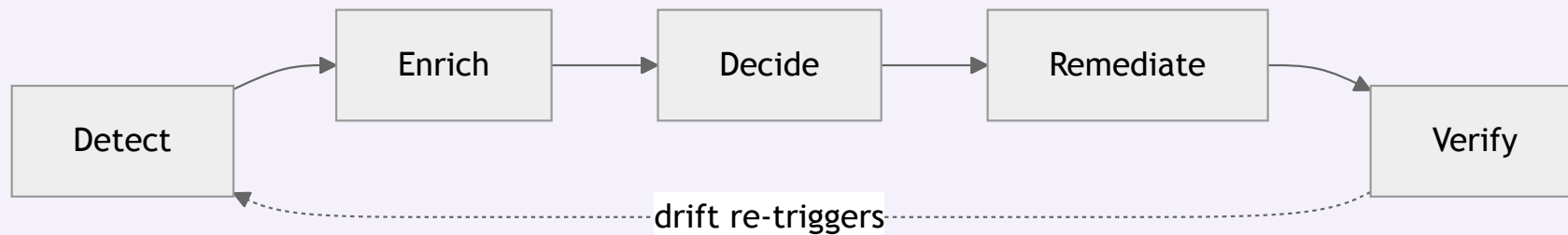
Remediation.

Detecting misconfigurations, flagging drift, generating findings → solved.

The real problem was never seeing the issues. It's **fixing them**.



Closing the loop



Most tooling stops after step 1. The loop only closes if **Remediate** is a real step, not a Slack ping.



Why auto-remediation is hard



Context is complex

Is this bucket public on purpose? Is this SG "temporary" for a reason someone forgot to document?



Alert fatigue

At ~2000 controls processed a day, humans triaging one by one doesn't scale.



Tool sprawl

Every provider, every framework, its own remediation story — if it has one at all.



Risk of breaking production

An automated fix that's wrong once is worse than a finding that sits open.





Farris's Three Laws of Security Auto-Remediation

I

A bot must never harm stateful data, or allow stateful data to come to harm.

II

A bot must act with utmost haste, so functionality doesn't become dependent on a misconfiguration.

III

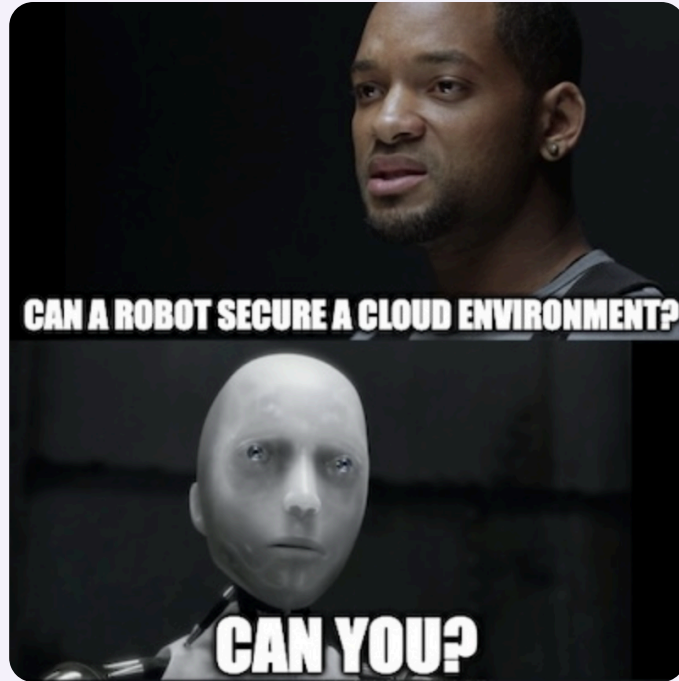
A bot must announce its existence and tell a carbon-based life form what it did, and why.



<https://www.chrisfarris.com/post/three-laws/>



Farris's Three Laws of Security Auto-Remediation



(stolen meme)



Different paths to auto-remediation

Native

- ✓ Easy to start
- ✗ Limited cross-provider surface
- ✗ Harder to customize

3rd Party

- ✓ Easy to start (if it supports your platforms)
- ✗ More cost per finding / asset
- ✗ Limited customization

Build Your Own

- ✓ Fully customizable
- ✗ Needs know-how

(or you can combine them)

We chose Build Your Own because we needed a tool that fits our:

- exception process
- ownership boundaries
- bypass method



But is there any AI?

- 🔍 We're still exploring
- 🛡️ Guardrails and constraints are non-negotiable
- 🧑 Human in the loop
- 🤖 AI helped build the slides, does that count?



Why we chose a custom implementation



The environment we actually run

AWS FOOTPRINT

2

AWS Organizations

60+

accounts

19

regions in use

20K+

resources / account

BEYOND AWS

5+ other Cloud Providers and SaaS



4

different internal platforms

~2000

control evaluations / day

3 people in the team

Highly regulated company

Multi account / region / cloud. Mixed IaC and legacy resources.



The trade-offs we accepted

WHAT IT COSTS US

- In-house know-how required, and it has to be maintained
- Small team owns more surface area
- Slower time-to-value than flipping a switch

WHAT IT BUYS US

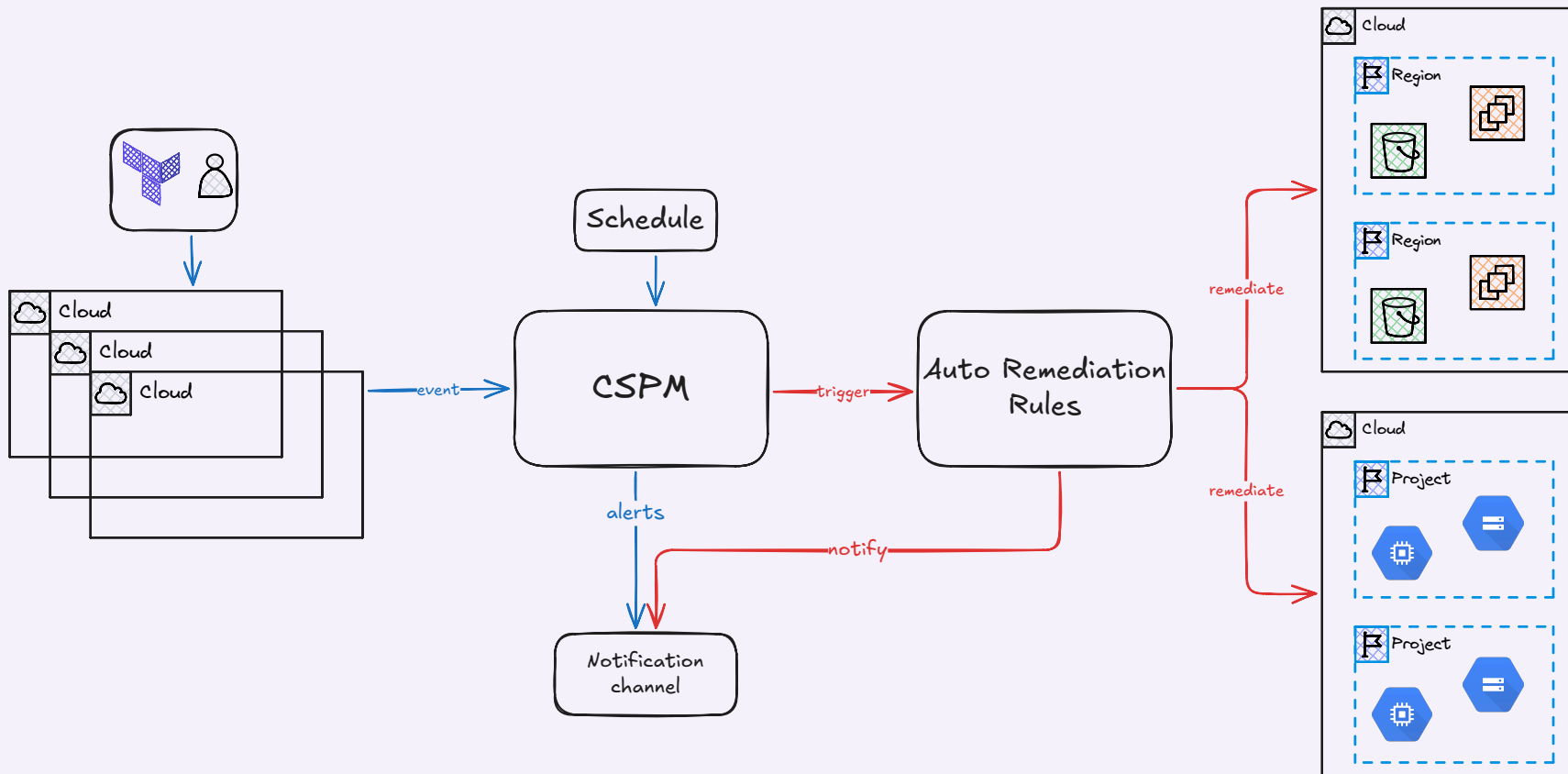
- Full customization — our exceptions, our workflow, our rules
- No per-finding or per-asset licensing cost
- Fits our existing IaC and CI patterns instead of fighting them



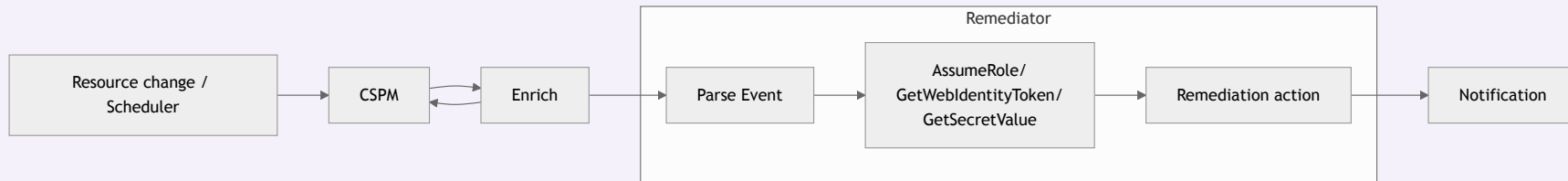
Architecture of our custom implementation



High level overview



Remediator



Amazon Q APP 8:24 PM

replied to [a thread](#)



Remediation Executed: aws_s3_bucket_restrict_public_access

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`



Custom notification delivered by Amazon Q Developer

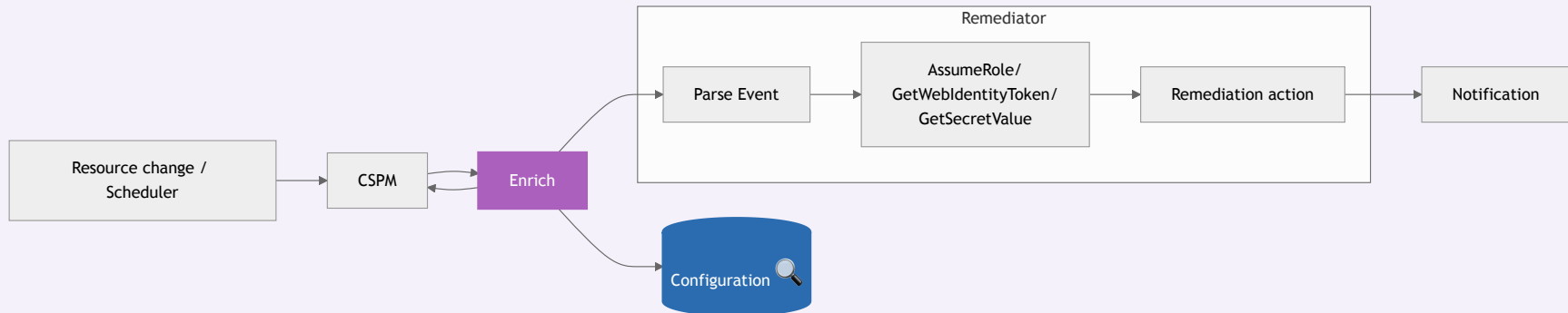


Guardrails

Configuration, Lock, Bypass — how automation earns trust.



Guardrails — Configuration

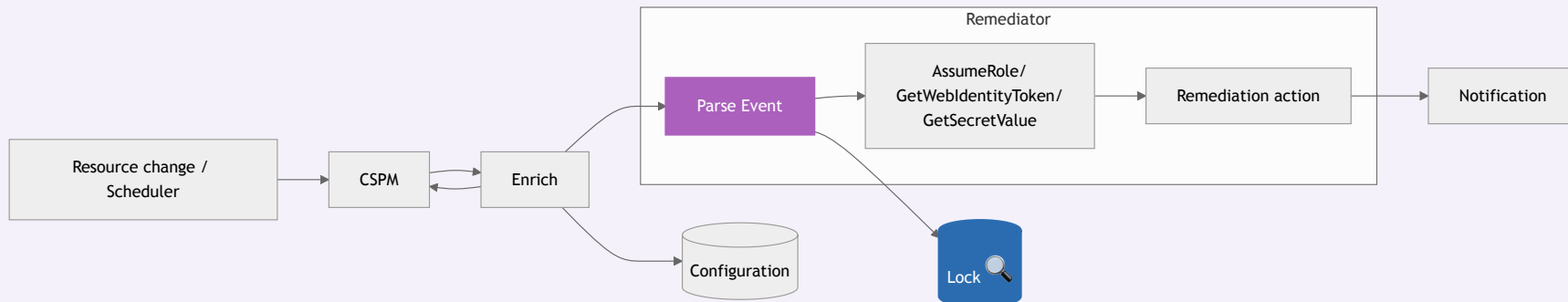


```
{
  "control": "aws_s3_public_bucket",
  "provider": "aws",
  "enabled": true,
  "scope": {
    "enabled": ["*"],
    "disabled": ["123456789012"]
  },
  "exceptions": [
    "arn:aws:s3::public-s3-bucket-exception-1"
  ]
}
```

Enrich checks the configuration allowlist. If allowed, it moves to remediate.



Guardrail — Lock

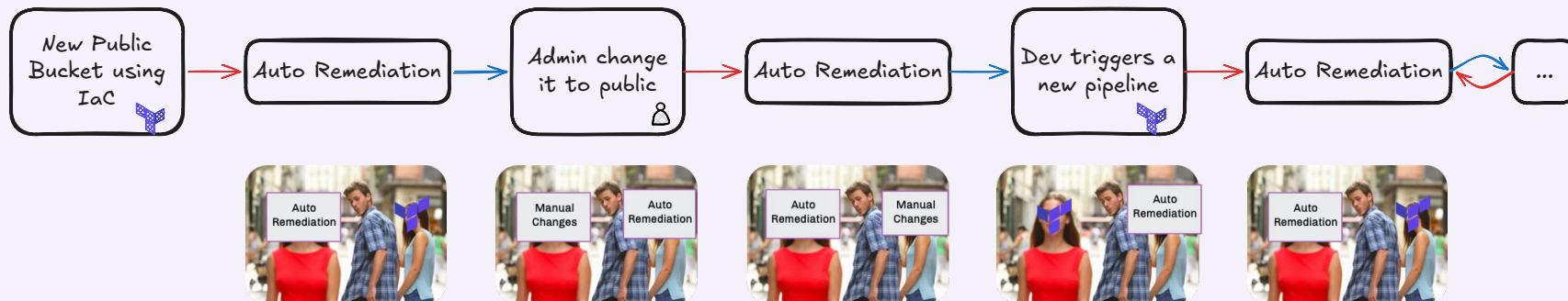


```
{
  "resource_identifier": "arn:aws:s3:::public-s3-bucket-exception-1",
  "control": "aws_iam_password_policy",
  "ttl": 1754899200
}
```

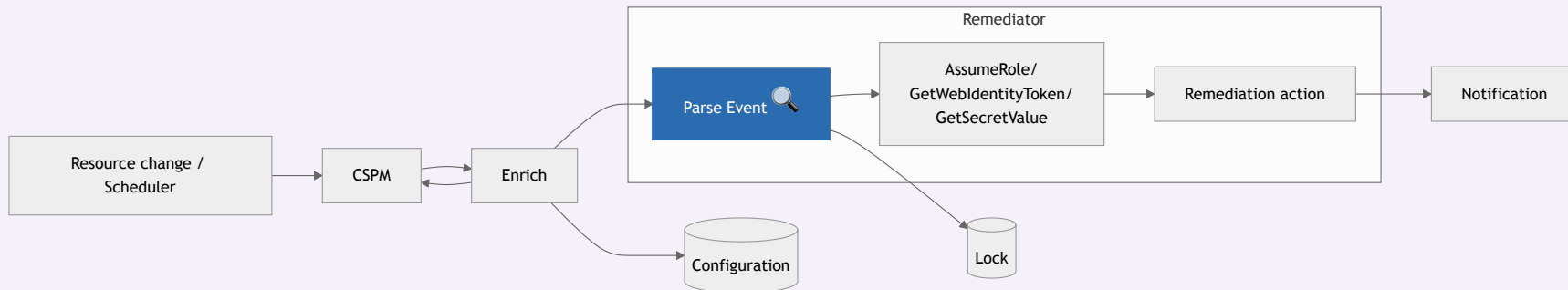
Lock stops the same resource from being remediated again in a loop for a bounded time.



Guardrail — Lock



Guardrail — Bypass

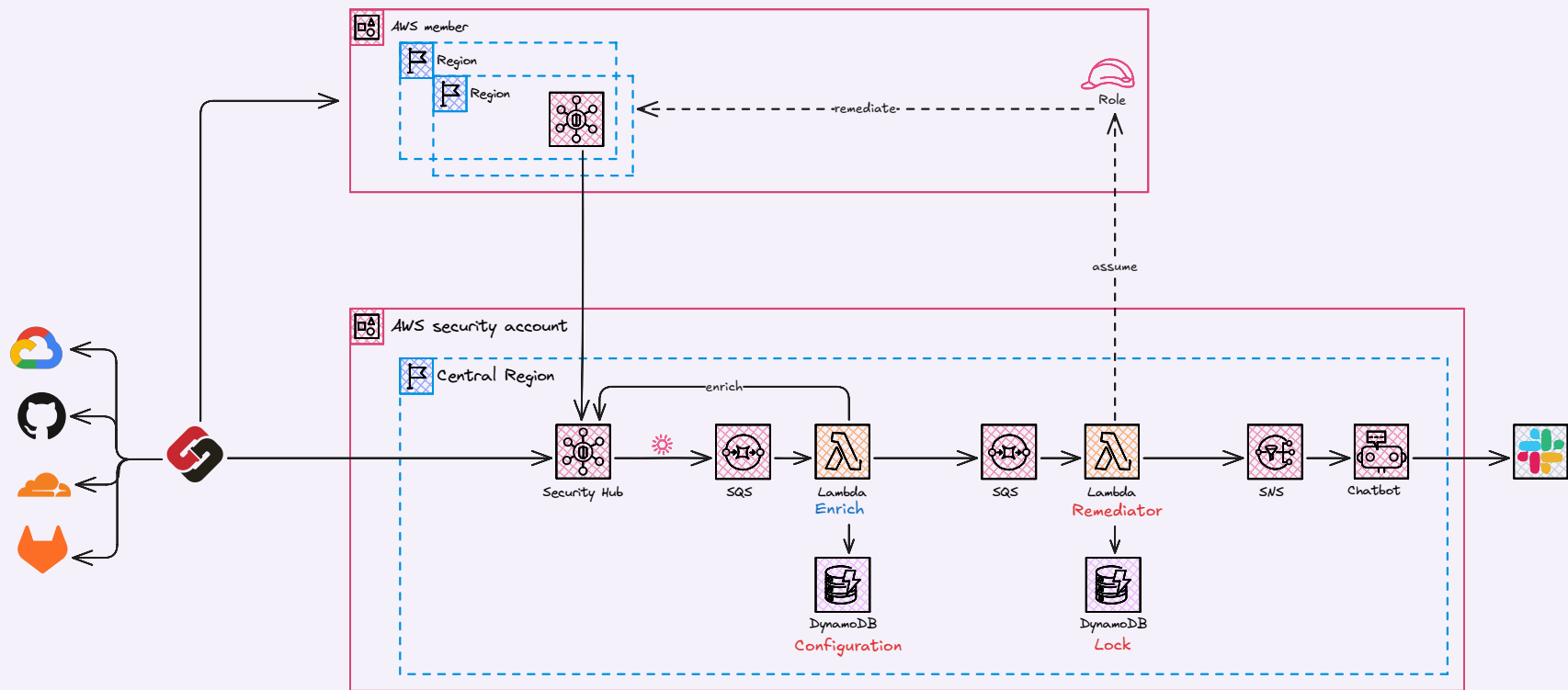


```
for _, tag := range event.Tags {
    if tag.Key == "disable-remediation" && tag.Value == "true" {
        skipRemediation()
        break
    }
}
```

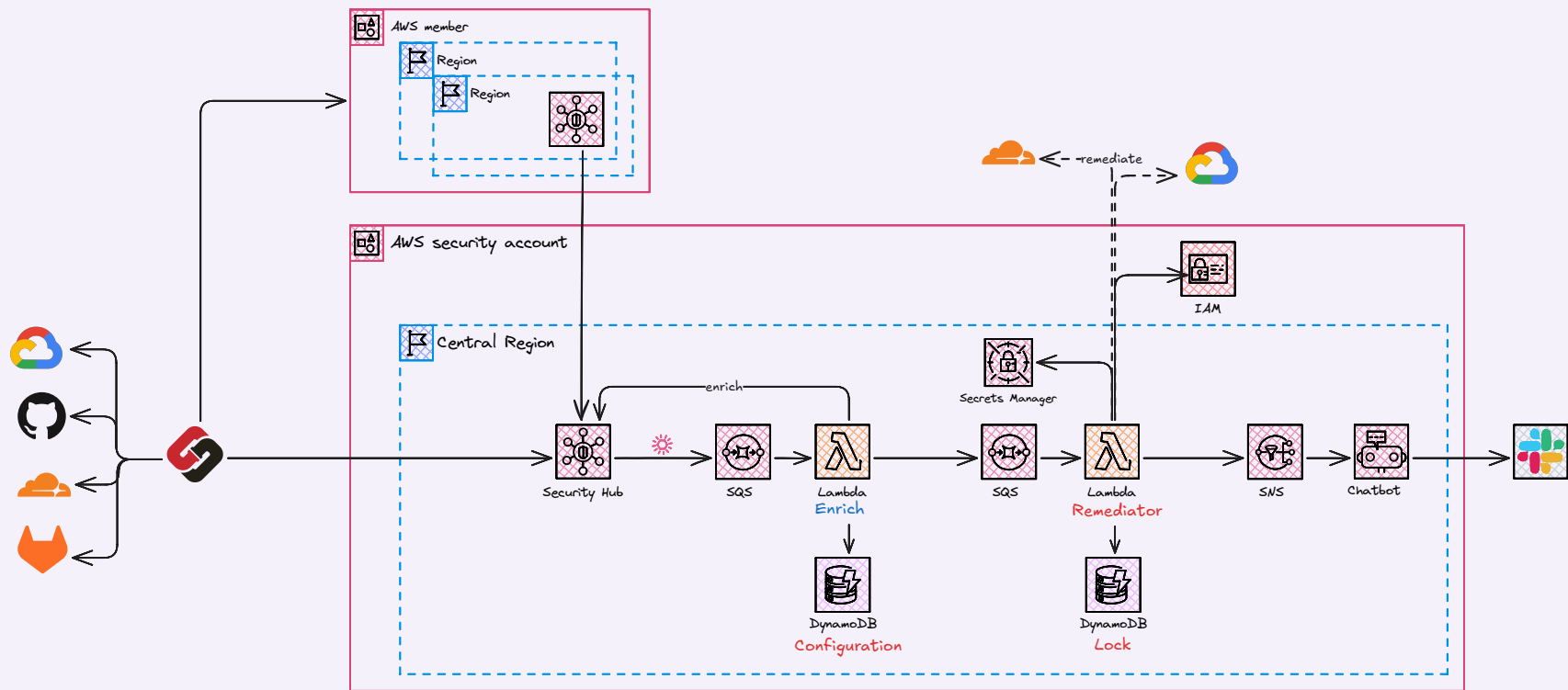
Last barrier, checked after Configuration and Lock. If `disable-remediation` is set, remediation is skipped and a Skip alert is sent instead.



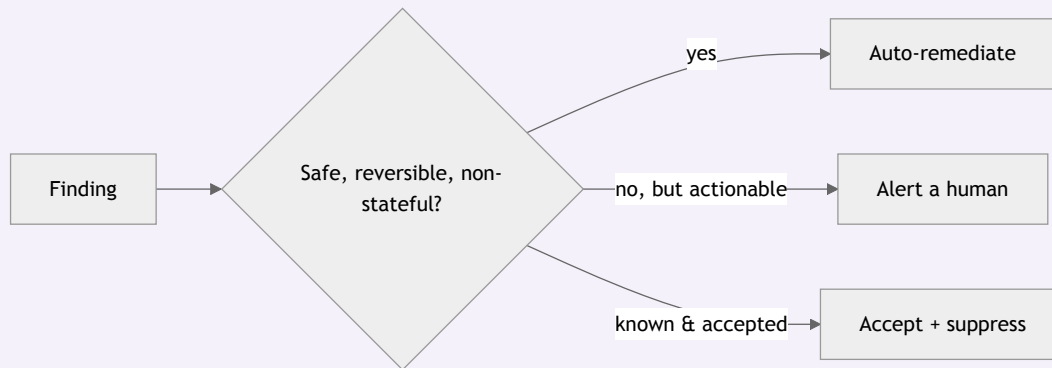
Architecture, for real



Architecture, for real



Deciding: remediate, alert, or accept



GOOD FIRST CANDIDATES

- Set account controls - public AMIs / EBS snapshots
- Set default encryption rules per account / project
- Revert new public blob storage resources
- Delete new 0.0.0.0/0 firewall rules
- Set account password policy
- Delete root access keys
- Enabling security services
- Enable KMS rotation
- Set Cloudflare zone min TLS version

WE DELIBERATELY DON'T AUTO-REMEDiate

- Anything touching stateful data directly
- Findings with no safe, automatic rollback
- A finding type we've never seen before



Lessons learned in production



Always track what's happening

Every remediation logs its outcome — executed, skipped, or failed — along with provider, control, and resource.

 **Amazon Q** APP 8:24 PM
replied to [a thread](#)

 **Remediation Executed: aws_s3_bucket_restrict_public_access**

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`

 Custom notification delivered by Amazon Q Developer

 **Amazon Q** APP 8:24 PM
replied to [a thread](#)

 **Remediation Executed: aws_s3_bucket_restrict_public_access**

The following remediation was executed:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-3`

 Custom notification delivered by Amazon Q Developer

 **Amazon Q** APP 8:28 PM
replied to [a thread](#)
 **Remediation Skipped: aws_s3_bucket_restrict_public_access**

The following remediation was skipped due to an existing lock:

- **Provider:** aws
- **Control:** aws_s3_bucket_restrict_public_access
- **Resource:** `arn:aws:s3:::remediator-demo-2`

 Custom notification delivered by Amazon Q Developer



The bypass method is ~~recommended~~ mandatory

0 production incidents
(at this moment 🙅)



Use it for more than just misconfigurations



<https://youtu.be/xlF1bqEPBY8>

A YouTube video player thumbnail for a SANS CloudSecNext 2025 event. The background is dark blue with a stylized orange and red mountain range at the bottom. The SANS logo is in the top left. The main title is 'IaC Meets Reality: Engineering for the Cloud You Actually Have'. Below it, the speakers are listed: Andoni Alonso, Cloud Security Engineer, Prowler, and Samuel Burgos, Cloud Security Engineer, Flywire. Two circular headshots of the speakers are on the right. At the bottom, it says 'Summit: Oct 2 - 3 | Training: Oct 4 - 9' and 'Live, CO & Live Online'. The CloudSecNext 2025 logo is in the bottom right. A red YouTube play button icon is in the top right corner. A small image of a SPAM can is overlaid on the bottom left of the video player.



The wins

+5h

saved per week

24h-7d → <5min

response time

\$100K → \$1.5K/yr

tooling cost, while infra doubled and expanded to new providers



Demo



Questions? 🦄

Samuel

 sbldevnet

 in/samuelburgos

Andoni

 andoniaf

 in/andoniaf

unicrons.cloud

 unicrons

 unicrons.cloud

Find this & other talks at unicrons.cloud/talks

